



Security Fundamentals

Use this when: you start in security or help desk and need the core ideas, and the words analysts use, in one place.

Security+ · CC · CySA+
Sheet v1.0 · Oct 2026

The CIA triad: what security protects

Every control serves one or more

Confidentiality

Only authorized people can see the data.

BROKEN BY Data leak, stolen password
PROTECT Encryption, access control

Integrity

Data stays accurate and unaltered.

BROKEN BY Tampering, malware
PROTECT Hashes, signatures

Availability

Systems and data work when needed.

BROKEN BY Ransomware, DDoS, outage
PROTECT Backups, redundancy, patching

AAA: who, what, did what

Authentication Prove who you are

Authorization What you may do once in

Accounting Log what you did (audit trail)

MFA 2+ factor types: **KNOW** (password), **HAVE** (app, key), **ARE** (fingerprint)

Risk in plain words

Asset Anything worth protecting

Threat Something that could cause harm

Vulnerability A weakness; an exploit uses it

Risk = **Likelihood** × **Impact**

Control types

Technical, managerial, operational, physical

Preventive	Stops it happening	Firewall, MFA
Deterrent	Discourages attackers	Warning banner, cameras
Detective	Spots it happening	IDS, log review
Corrective	Fixes the damage	Restore from backup
Compensating	Stand-in when you can't	Extra logging
Directive	Tells people what to do	Security policy

Design principles

Least privilege	Only the access the job needs
Defense in depth	Layers, so one failure is not fatal
Zero trust	No trust from network location alone
Separation of duties	No one controls a whole process
Non-repudiation	Can't deny an action (signatures, logs)

NIST CSF 2.0: six functions

Run as a continuous cycle

Govern Strategy, policy	Identify Assets and risks	Protect Reduce risk	Detect Find attacks	Respond Act on incidents	Recover Restore operations
-----------------------------------	-------------------------------------	-------------------------------	-------------------------------	------------------------------------	--------------------------------------

Key terms

CVE	Public ID for a known vulnerability
Zero-day	Exploited before a patch exists
IOC	Evidence of compromise (IP, hash)
IDS / IPS	Detects / detects and blocks
SIEM	Collects and correlates logs
EDR	Endpoint monitoring and response

Stay safe and legal

DANGER Suspect a breach? Disconnect, do not wipe, escalate.

LEGAL Test only what you own or have written permission for.

CAUTION Never share MFA codes with anyone.



● **C-I-A**: Confidentiality, Integrity, Availability

● Authentication is **who**; authorization is **what**

● No control is perfect: use **layers**